

Dominios de la Ciberseguridad

en el NIST Cybersecurity Framework 2.0

Exposición N.o 1 · Unidad 1 · Módulo: Ciberseguridad en la Transformación Digital

1

JUAN CARLOS CAMPOS
BASURTO

2

HECTOR AARON LLERENA
AGUILERA

3

JOSUE NICOLAS COZZARELLI
JIMENEZ

4

MARCOS DANIEL TERAN
CRUZ

Programa: Maestría en Tecnologías de la Información, mención en Transformación Digital e Innovación

Docente: Mgs. María Daniela Alvarez Galarza

Link exposición: https://drive.google.com/drive/folders/11lvFHKj65HnIVaT_24iJZTqSNwVZAfvV?usp=sharing

Milagro, Ecuador · 11 de abril de 2026

Agenda y distribución del equipo

20 minutos de exposición + 5 minutos de preguntas

1

Expositor 1

Introducción

Justificación, organización de referencia, que es el CSF 2.0, procedimiento de implementación.

Diap. 1 - 7 · 5 min

2

Expositor 2

Cierre de introducción y GOBERNAR

Limitaciones, aportaciones y la función GOBERNAR (6 categorías) + IDENTIFICAR.

Diap. 8 - 14 · 5 min

3

Expositor 3

PROTEGER, DETECTAR y RESPONDER

Las tres funciones operativas: controles preventivos, monitoreo y manejo de incidentes.

Diap. 15 - 21 · 5 min

4

Expositor 4

RECUPERAR y cierre

Recuperación, síntesis integrada, niveles de madurez, conclusiones y recomendaciones.

Diap. 22 - 29 · 5 min

Todos los integrantes sustentan; el orden sigue la lógica del marco: primero se gobierna, luego se identifica, se protege, se detecta, se responde y se recupera.

Por qué y para qué implementar ciberseguridad

La transformación digital amplía la superficie de ataque a la misma velocidad que crea valor

USD 4,44 M

Costo promedio global de una brecha de datos (IBM, 2025). El informe 2026 reporta un alza del 12 % y un nuevo máximo histórico.

241 días

Tiempo promedio para identificar y contener una brecha. Superar los 200 días encarece el incidente de forma significativa.

1 de cada 6

Brechas donde el vector fue la cadena de suministro, hoy el segundo vector más frecuente a nivel mundial.

1

Por qué

El riesgo cibernético dejó de ser un problema técnico: hoy interrumpe la operación, destruye reputación y genera sanciones regulatorias.

2

Para qué

Para proteger la continuidad del negocio, la información de los socios y la capacidad de la organización de seguir digitalizándose con confianza.

3

Con qué medio

Con un marco de referencia reconocido: el NIST Cybersecurity Framework 2.0, que traduce el riesgo cibernético al lenguaje de la alta dirección.

Organización de referencia y sus procesos de negocio

Cooperativa de Ahorro y Crédito ANDINA Ltda. (caso hipotético) - 12 agencias, 180 colaboradores, 45.000 socios

Captación de ahorros

Apertura de cuentas, depósitos, certificados a plazo fijo.

Colocación de crédito

Originación, análisis, aprobación y desembolso.

Canales digitales

Banca web, aplicación móvil y cajeros automáticos.

Cobranza y recuperación

Gestión de cartera vencida y call center.

Cumplimiento regulatorio

Reportes al organismo de control y protección de datos.

Soporte y proveedores

Core financiero tercerizado, switch transaccional, nube.

Activos críticos que sostienen esos procesos

Core financiero · Base de datos de socios (datos personales y financieros) · Aplicación móvil y banca web · Switch transaccional · Directorio de identidades · Respalos · Enlaces de comunicación entre agencias

Todos los controles que se presentan a continuación se explican sobre estos procesos y activos, no en abstracto.

Qué es el NIST Cybersecurity Framework 2.0

Publicado en febrero de 2024 (NIST CSWP 29). Voluntario, agnóstico a la tecnología y orientado a resultados, no a productos

1

El Núcleo (Core)

6 funciones, 22 categorías y más de 100 subcategorías. Describe RESULTADOS de ciberseguridad que la organización debe alcanzar, no los controles específicos para lograrlos.

2

Los Perfiles

Perfil Actual (donde estamos) frente a Perfil Objetivo (donde queremos estar). La diferencia entre ambos es el análisis de brechas que origina el plan de acción.

3

Los Niveles (Tiers)

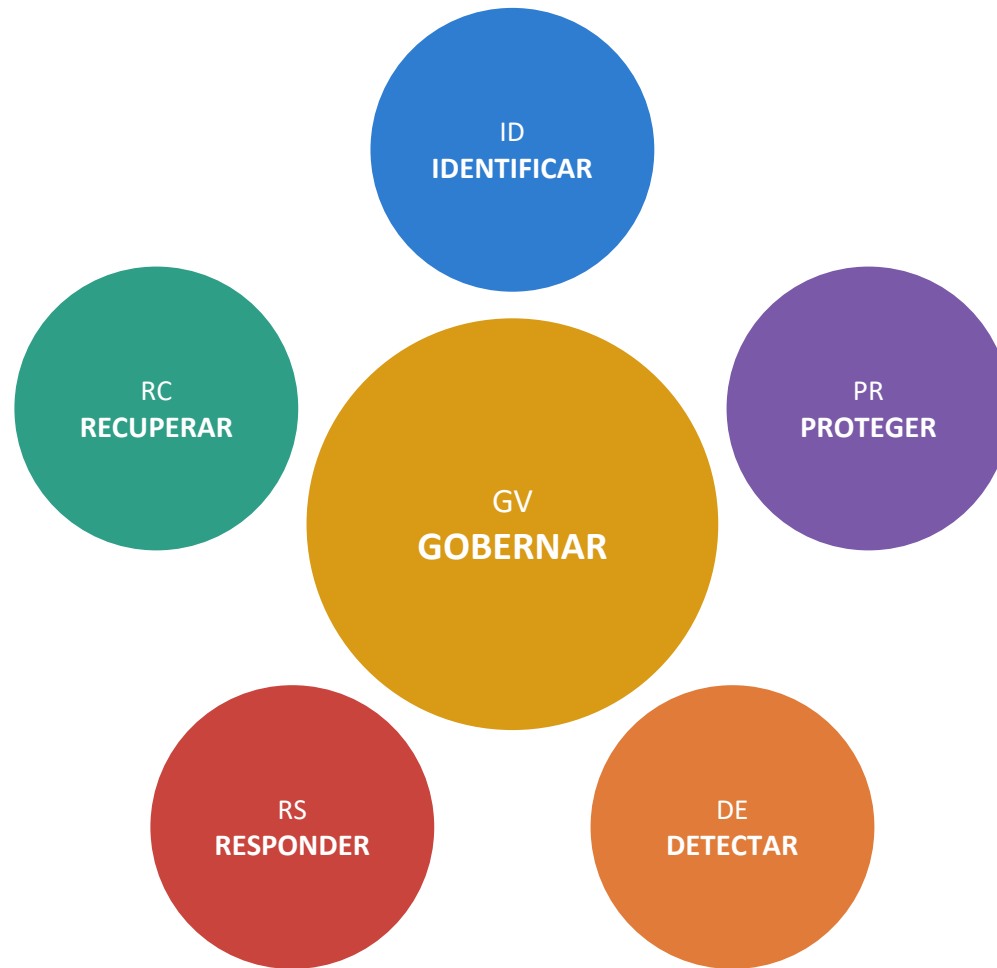
Cuatro grados de rigor en la gestión del riesgo: Parcial, Informado por riesgo, Repetible y Adaptativo. Expresan qué tan integrada está la ciberseguridad en el negocio.

Qué cambió frente a la versión 1.1

- Se incorporó GOBERNAR como sexta función, ubicada en el centro del marco.
- Se amplió el alcance: ya no aplica solo a infraestructura crítica, sino a toda organización.
- Se reforzó la gestión del riesgo de la cadena de suministro y su mapeo a ISO 27001, COBIT y NIST SP 800-53.

Las seis funciones del marco

GOBERNAR es transversal: informa y condiciona a las otras cinco



- GOBERNAR (6 categorías)**
Establece y supervisa la estrategia, las expectativas y la política de riesgo cibernético.
- IDENTIFICAR (3 categorías)**
Comprende los activos, los proveedores y los riesgos de la organización.
- PROTEGER (5 categorías)**
Aplica salvaguardas para gestionar el riesgo identificado.
- DETECTAR (2 categorías)**
Encuentra y analiza posibles ataques y compromisos.
- RESPONDER (4 categorías)**
Actúa ante un incidente detectado para contener su efecto.
- RECUPERAR (2 categorías)**
Restaura los activos y las operaciones afectadas.

22 categorías en total. Las funciones no son fases secuenciales: operan de forma simultanea y continua.

Procedimiento para implementar los controles

Ciclo de mejora continua, no un proyecto con fecha de cierre



El resultado del paso 6 alimenta nuevamente al paso 2: el Perfil Actual se vuelve a medir cada año y el ciclo se repite.

Limitaciones de la implementación

Lo que el marco no resuelve por sí solo y conviene advertir a la alta dirección



No es un catálogo de controles

El CSF define resultados esperados, no procedimientos. Debe complementarse con ISO/IEC 27002, CIS Controls v8 o NIST SP 800-53.



Es voluntario y no certificable

No sustituye obligaciones legales como la Ley Orgánica de Protección de Datos Personales ni las normas del organismo de control.



Costo y escasez de talento

Un SIEM, un SOC 24x7 y perfiles especializados superan el presupuesto típico de una organización mediana.



Depende del compromiso directivo

Sin patrocinio del Consejo de Administración, GOBERNAR queda en papel y el resto de funciones pierde sustento.



Sistemas heredados y deuda técnica

Un core sin soporte del fabricante limita el endurecimiento, el cifrado y la aplicación de parches.



Medición cualitativa

La evaluación por perfiles depende del criterio del evaluador; sin evidencia objetiva se sobrestima la madurez.

Aportaciones de implementar estos controles

Qué gana concretamente la organización

1

Lenguaje común

Traduce el riesgo cibernético a terminos de negocio, de modo que el Consejo pueda decidir sobre el con la misma lógica que un riesgo de crédito.

2

Inversión priorizada

El análisis de brechas dirige el presupuesto a los procesos críticos en lugar de repartirlo por igual entre todas las áreas.

3

Menor impacto del incidente

Detección y contención más rápidas reducen de forma directa el costo, la interrupción y la pérdida de clientes.

4

Continuidad y confianza

Los canales digitales se mantienen disponibles; la confianza del socio se sostiene incluso ante un evento adverso.

5

Cumplimiento y auditoría

Facilita evidencias ante el regulador y el mapeo hacia ISO/IEC 27001, COBIT y PCI DSS sin duplicar esfuerzo.

6

Habilita la digitalización

Permite adoptar nube, movilidad e inteligencia artificial con controles definidos desde el diseño, no después del incidente.



GV

FUNCIÓN 1 DE 6

GOBERNAR

Establece, comunica y supervisa la estrategia, las expectativas y la política de gestión del riesgo cibernético. Es la función transversal: sin ella, las otras cinco carecen de autoridad, presupuesto y dirección.

GOBERNAR: seis categorías

Qué resultado busca cada una en la cooperativa

GV.OC

Contexto de la organización

Comprender misión, socios, partes interesadas y requisitos legales que condicionan las decisiones de riesgo.

GV.RM

Estrategia de gestión de riesgos

Definir apetito y tolerancia al riesgo, criterios de aceptación y como se financia el tratamiento.

GV.RR

Roles, responsabilidades y autoridades

Designar quién decide, quién ejecuta y quién responde por cada control (matriz RACI).

GV.PO

Política

Emitir, aprobar, comunicar y revisar periódicamente la política de seguridad de la información.

GV.OV

Vigilancia (supervisión)

Revisar los resultados obtenidos y ajustar la estrategia; rendición de cuentas al Consejo.

GV.SC

Riesgo de la cadena de suministro

Evaluar y controlar a proveedores críticos: core, nube, switch transaccional y soporte.

GOBERNAR: cómo se implementa

Todo control se materializa en políticas, tecnología y personas

Políticas

- Política General de Seguridad de la Información aprobada por el Consejo de Administración.
- Manual de gestión de riesgo tecnológico con apetito y tolerancia declarados.
- Política de gestión de terceros con cláusulas de seguridad y derecho de auditoría.
- Código de ética y acuerdos de confidencialidad.

Tecnología

- Herramienta GRC para registrar riesgos, controles y planes de acción.
- Repositorio documental con control de versiones y aprobaciones.
- Tablero de indicadores (KRI y KPI) para el Comité y el Consejo.
- Registro y clasificación de proveedores críticos.

Personas

- Comité de Seguridad de la Información con sesiones mensuales y actas.
- Oficial de Seguridad de la Información con reporte independiente de TI.
- Matriz RACI por proceso crítico y dueño de activo designado.
- Inducción en riesgo cibernético para el Consejo y la Gerencia.

Sin GOBERNAR, cualquier inversión en tecnología queda sin dueño, sin presupuesto sostenido y sin rendición de cuentas.



ID

FUNCIÓN 2 DE 6

IDENTIFICAR

Permite comprender los activos, proveedores y riesgos actuales de la organización. No se puede proteger lo que no se conoce: esta función produce el inventario y la matriz de riesgos sobre los que se prioriza todo lo demás.

IDENTIFICAR: categorías y medios de implementación

Tres categorías que alimentan directamente el plan de tratamiento del riesgo

ID.AM

Gestión de activos

Inventario de hardware, software, datos, servicios y proveedores, clasificado por criticidad para el negocio y con dueño asignado.

ID.RA

Evaluación de riesgos

Identificar amenazas y vulnerabilidades, estimar probabilidad e impacto y priorizar el tratamiento del riesgo.

ID.IM

Mejora

Capturar lecciones aprendidas de incidentes, pruebas y auditorías para corregir el programa de seguridad.

Medios de implementación

- Políticas: política de gestión de activos y metodología formal de riesgos (ISO/IEC 27005 o MAGERIT).
- Software: CMDB o GLPI para el inventario, escáner de vulnerabilidades (Nessus, OpenVAS), matriz de riesgos.
- Hardware: etiquetado y control de equipos, agentes de descubrimiento en la red interna.
- Personas: dueño de activo por proceso, levantamiento anual con las áreas, comité que aprueba el plan de tratamiento.

Resultado esperado: inventario vigente de activos críticos y matriz de riesgos priorizada, revisados al menos una vez al año.



PR

FUNCIÓN 3 DE 6

PROTEGER

Aplica las salvaguardas necesarias para gestionar los riesgos identificados. Es la función con mayor carga tecnológica y la que más depende del comportamiento de las personas.

PROTEGER: cinco categorías

Salvaguardas sobre los procesos críticos de la cooperativa

PR.AA	Identidad, autenticación y control de acceso	Acceso a sistemas limitado a usuarios autorizados, con mínimo privilegio y verificación de identidad.
PR.AT	Concienciación y capacitación	El personal cuenta con conocimiento y habilidades para ejecutar sus tareas de forma segura.
PR.DS	Seguridad de los datos	Confidencialidad, integridad y disponibilidad de la información en reposo, en tránsito y en uso.
PR.PS	Seguridad de las plataformas	Hardware, software y servicios gestionados de forma coherente con la política de riesgo.
PR.IR	Resiliencia de la infraestructura tecnologica	Arquitectura de red y capacidad diseñadas para resistir eventos adversos y sostener la operación.

Es la función con más categorías del marco: concentra los controles preventivos del día a día.

PROTEGER: cómo se implementa

Ejemplos aplicados a la cooperativa de referencia

Políticas

- Política de control de acceso y gestión de contraseñas con MFA obligatorio.
- Política de uso aceptable y de teletrabajo.
- Procedimiento de gestión de cambios y de parches.
- Política de respaldos con regla 3-2-1.

Hardware

- Firewall de nueva generación en el perímetro de cada agencia.
- WAF delante de la banca web y del canal móvil.
- Enlaces redundantes con proveedores distintos.
- Almacenamiento de respaldo dedicado y fuera de línea.

Software

- Gestor de identidades con inicio de sesión único y doble factor.
- EDR en servidores y estaciones de trabajo.
- Cifrado de datos en reposo y en tránsito (TLS, cifrado de disco y de base de datos).
- Segmentación de red que aisla el core del resto.

Personas

- Plan anual de capacitación en seguridad para todo el personal.
- Simulacros de phishing trimestrales con medición de tasa de clic.
- Revisión semestral de accesos por dueño de proceso.
- Baja inmediata de accesos al cesar la relación laboral.

El control técnico y el control humano se sostienen mutuamente: el doble factor no sirve si el personal aprueba cualquier notificación que recibe.



DE

FUNCIÓN 4 DE 6

DETECTAR

Encuentra y analiza posibles ataques y compromisos. Su valor se mide en tiempo: cada día que un atacante permanece sin ser detectado incrementa el costo y el alcance del incidente.

DETECTAR: categorías y medios de implementación

Dos categorías orientadas a reducir el tiempo medio de detección (MTTD)

DE.CM

Monitoreo continuo

Vigilar activos, red, personal, entorno físico y servicios de terceros para encontrar eventos potencialmente adversos.

DE.AE

Análisis de eventos adversos

Correlacionar, triar y escalar los eventos para caracterizarlos y declarar formalmente un incidente.

Indicador clave

MTTD: tiempo medio entre el inicio del compromiso y su detección. Es la métrica que debe reportarse al Comité cada mes.

Medios de implementación

- Políticas: política de registro y monitoreo, retención de logs y clasificación de severidad de eventos.
- Software: SIEM (Wazuh, Splunk o Microsoft Sentinel), EDR, detección de intrusos en red y reglas de correlación por caso de uso.
- Hardware: sensores de red en agencias, sincronización horaria con servidor NTP y almacenamiento centralizado de registros.
- Personas: turnos de analistas o servicio de SOC gestionado 24x7, con matriz de escalamiento definida.

A large red circle containing the white letters 'RS' in a serif font.

RS

FUNCIÓN 5 DE 6

RESPONDER

Ejecuta las acciones necesarias ante un incidente detectado para contener su efecto. La improvisación durante un incidente es lo que convierte un evento controlable en una crisis institucional.

RESPONDER: categorías y medios de implementación

El plan de respuesta se activa, se ejecuta y se comunica



Medios de implementación

Políticas

Plan de Respuesta a Incidentes alineado a NIST SP 800-61, con matriz de severidad, tiempos de reporte al regulador y cadena de custodia de la evidencia.

Tecnología

Plataforma de tickets o SOAR con libretas de acción (ransomware, phishing, fuga de datos), herramientas forenses y capacidad de aislar equipos de forma remota.

Personas

Equipo de respuesta (CSIRT) con roles definidos, vocero único, asesoría legal y canal de comunicación alternativo fuera de la red comprometida.

Indicador clave: MTTR, tiempo medio de contención y respuesta.



RC

FUNCIÓN 6 DE 6

RECUPERAR

Restaura los activos y las operaciones afectadas por el incidente. Cierra el ciclo y devuelve a la organización a la normalidad, alimentando con lecciones aprendidas a las funciones de GOBERNAR e IDENTIFICAR.

RECUPERAR: categorías, medios y métricas

Dos categorías que determinan cuánto dura realmente la interrupción

RC.RP

Ejecución del plan de recuperación

Restaurar los sistemas según la prioridad definida en el análisis de impacto, verificar integridad antes de reconectar y declarar formalmente el retorno a la operación normal.

RC.CO

Comunicación en la recuperación

Informar el avance de la restauración a socios, personal, organismo de control y, cuando corresponde, a los medios, con mensajes preaprobados.

Métricas que se acuerdan con el negocio, no con TI

RTO: cuánto tiempo puede estar caído el proceso. RPO: cuánta información puede perderse.

Medios de implementación

- Políticas: plan de continuidad del negocio y de recuperación ante desastres, derivados de un análisis de impacto (BIA).
- Tecnología: respaldos inmutables y fuera de línea, replicación a sitio alternativo o nube, imágenes base de servidores.
- Personas: pruebas de restauración semestrales documentadas y comunicado institucional preaprobado por Legal y Marketing.

Un respaldo que nunca se restaura en una prueba no es un respaldo: es una suposición.

Síntesis: de la función al control concreto

Cómo se traduce cada función en política, tecnología y responsable dentro de la cooperativa

FUNCIÓN	POLÍTICA CLAVE	TECNOLOGÍA CLAVE	RESPONSABLE
GOBERNAR	Política General de Seguridad	Herramienta GRC y tablero de riesgos	Consejo y Comité de Seguridad
IDENTIFICAR	Metodología de gestión de riesgos	CMDB y escáner de vulnerabilidades	Oficial de Seguridad
PROTEGER	Política de control de acceso	IAM con MFA, EDR, cifrado, WAF	Jefatura de Infraestructura
DETECTAR	Política de registro y monitoreo	SIEM con casos de uso y SOC 24x7	Analista de seguridad / SOC
RESPONDER	Plan de Respuesta a Incidentes	SOAR, libretas de acción, forense	Equipo de respuesta (CSIRT)
RECUPERAR	Plan de continuidad y recuperación	Respaldos inmutables y sitio alternativo	Gerencia de Operaciones

Ninguna función es opcional: si falta DETECTAR, los controles de PROTEGER fallan en silencio; si falta RECUPERAR, un incidente contenido igual detiene el negocio.

Niveles de madurez y hoja de ruta sugerida

Los Tiers indican el rigor de la gestión del riesgo; la hoja de ruta ordena la ejecución

1

Parcial

Gestión reactiva e informal, sin conciencia del riesgo organizacional.

2

Informado por riesgo

Prácticas aprobadas por la dirección, pero aplicadas de forma no uniforme.

3

Repetible

Política formal, procesos definidos y actualizados con regularidad.

4

Adaptativo

La organización se adapta activamente al cambio en el panorama de amenazas.

Hoja de ruta de 12 meses



0 - 90 días

Comité de Seguridad, política general aprobada, inventario de activos críticos y evaluación inicial de riesgos.



91 - 180 días

MFA en accesos críticos, respaldos 3-2-1 probados, gestión de parches y plan de capacitación en marcha.



181 - 365 días

SIEM con casos de uso, plan de respuesta a incidentes probado en simulacro y plan de continuidad validado.

Una organización mediana rara vez necesita el Nivel 4: la meta realista es alcanzar el Nivel 3 en los procesos críticos.

Conclusiones

Ideas principales que se desprenden de la exposición, en síntesis y sin repetir los controles

1

El NIST CSF 2.0 no es una lista de tecnologías que se compran, es un modelo de gestión que exige, sobre todo, decisión y patrocinio de la alta dirección. Sin GOBERNAR funcionando de verdad, todo lo demás —el firewall, el SIEM, el plan de respuesta— queda sin dueño y sin sostenibilidad en el tiempo.

2

Las seis funciones son interdependientes, no independientes. Vimos que si falla DETECTAR, PROTEGER falla en silencio; y si falla RECUPERAR, un incidente ya contenido igual detiene el negocio. La ciberseguridad madura no se mide por tener un solo control fuerte, sino por que ninguna de las seis funciones esté ausente.

3

Para una organización como la cooperativa que usamos de referencia, el objetivo realista no es la perfección tecnológica, es alcanzar el Nivel 3 —Repetible— en sus procesos críticos, con una hoja de ruta clara de 12 meses, presupuesto asignado y revisión anual del Perfil Actual.

Recomendaciones

Acciones precisas y claras dirigidas a la organización: qué hacer, quién y con qué plazo

1

El Consejo de Administración debe aprobar formalmente la Política General de Seguridad de la Información y conformar el Comité de Seguridad en los primeros 90 días, con sesiones mensuales documentadas. Responsable: Consejo de Administración. Plazo: 90 días.

2

La Jefatura de Infraestructura debe implementar MFA en todos los accesos críticos —core financiero, banca web y aplicación móvil— y ejecutar una prueba real de restauración de respaldos, no solo confirmarlos en papel. Responsable: Jefatura de Infraestructura. Plazo: 180 días.

3

El Oficial de Seguridad de la Información debe liderar un simulacro de respuesta a incidentes con el equipo CSIRT, incluyendo un escenario de ransomware, y presentar los resultados al Comité de Seguridad. Responsable: Oficial de Seguridad de la Información. Plazo: 365 días.

Referencias bibliográficas

Formato APA, séptima edición

Asamblea Nacional del Ecuador. (2021). Ley Orgánica de Protección de Datos Personales. Registro Oficial Suplemento 459.

Center for Internet Security. (2021). CIS Critical Security Controls, versión 8. CIS.

Cichonski, P., Millar, T., Grance, T., & Scarfone, K. (2012). Computer security incident handling guide (NIST Special Publication 800-61, Rev. 2). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-61r2>

IBM Security & Ponemon Institute. (2025). Cost of a data breach report 2025. IBM Corporation. <https://www.ibm.com/reports/data-breach>

International Organization for Standardization. (2022). ISO/IEC 27001:2022. Information security, cybersecurity and privacy protection - Information security management systems - Requirements. ISO.

Joint Task Force. (2020). Security and privacy controls for information systems and organizations (NIST Special Publication 800-53, Rev. 5). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-53r5>

National Institute of Standards and Technology. (2024). The NIST Cybersecurity Framework (CSF) 2.0 (NIST CSWP 29). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.CSWP.29>

Verificar el año de consulta y añadir las fuentes adicionales que el equipo utilice.



Gracias por su atención

Quedamos atentos a sus preguntas